ISO 27001, SOC2 & Annex A controls

ISO 27001

ISO/IEC 27001 is an international standard for Information Security Management Systems (ISMS). It provides a framework for organizations to protect sensitive information from threats such as cyberattacks, data breaches, unauthorized access, and data loss. This is certifiable, a company can get formally audited and certified against it. It certifies an organization's Information Security Management System (ISMS), confirming that it meets the requirements of the ISO/IEC 27001 standard within a defined scope.

ISO 27001 certification is an independent assessment confirming that an organization's ISMS meets the requirements of the standard within the defined certification scope.

An **ISMS (Information Security Management System)** is a systematic approach to managing an organization's information security risks. It follows the Plan-Do-Check-Act cycle.

It helps organizations ensure that their information remains confidential, accurate, and available when required.

Main Objectives of ISO 27001:

1) Confidentiality
2) Integrity
3) Availability

Features of ISO 27001:

- Risk management
- Security
- Access Control
- Incident Management
- Internal audits
- Business continuity

ISO/IEC 27001:2022 is the widely used edition of the standard. Its **Annex A** contains 93 reference security controls, grouped into four categories:

1. Organizational controls
2. People controls
3. Physical controls
4. Technological controls

Working of ISO 27001:



Example of ISO 27001 in a company

Suppose an employee at a software company clicks a phishing link and an attacker steals their login credentials.

The company applies ISO 27001 by investigating the incident, assessing the risk of unauthorised access, and checking whether customer information was exposed.

It may disable the compromised account, reset credentials, review access logs, and notify the appropriate stakeholders according to its incident response procedures and applicable legal requirements.

After containing the incident, the company identifies the weaknesses that allowed it to happen. It might strengthen MFA enforcement, improve phishing awareness training, and enhance suspicious-login monitoring.

The company documents the incident, updates its risk assessment where necessary, and verifies that corrective actions have been implemented.

This illustrates how ISO 27001 connects risk assessment, security controls, incident response, documentation, and continuous improvement.

Annex A Controls

Annex A is a list of 93 controls (in the 2022 version) organized into 4 themes: Organizational, People, Physical, Technological.

Control area	Example control	Plain-language explanation
Access control	A.5.15	Only give people access to the data/systems they actually need (least privilege)
Asset management	A.5.9	Keep an inventory of all information assets (devices, data, software)
Cryptography	A.8.24	Use encryption to protect sensitive data
Physical security	A.7.1	Secure physical areas like server rooms with badge access
Human resource security	A.6.1	Background checks before hiring for sensitive roles
Supplier relationships	A.5.19	Vet third-party vendors for security practices before working with them
Incident management	A.5.24	Have a defined process for handling security incidents
Information security during disruption	A.5.29	Plan for how IT systems keep running, or are quickly restored, during and after a disruption
Change management	A.8.32	Formal approval process before changing systems/software
Logging	A.8.15	Keep logs of system activity to detect and investigate issues.
Backup	A.8.13	Regular data backups to recover from loss/attack
Monitoring Activities	A.8.16	Watch systems and networks for unusual behaviour.
Network security	A.8.20	Segment networks, use firewalls to control traffic
Malware protection	A.8.7	Antivirus/anti-malware tools deployed across systems
Secure development	A.8.25	Security built into the software development lifecycle, not bolted on after
Data masking	A.8.11	Hide/obscure sensitive data in non-production environments
Vulnerability management	A.8.8	Regularly scan for and patch known vulnerabilities

SOC 2

SOC 2 stands for System and Organization Controls 2. It is a security auditing and reporting framework used to evaluate how well a company protects customer data and manages information security risks.

It is especially relevant to companies that provide cloud services, SaaS applications, data storage, and other technology services.

For example, if a company stores your personal data on its cloud servers, SOC 2 helps demonstrate whether the company has appropriate controls to protect that data.

A SOC 2 audit evaluates the company's controls against five Trust Services Criteria:
1) Security
2) Availability
3) Processing Integrity
4) Confidentiality
5) Privacy

Criteria	What it covers	Example
Security (mandatory in every SOC 2 report)	Protection against unauthorized access	Firewalls, access controls, intrusion detection
Availability	System uptime and operational reliability	Redundancy, disaster recovery, uptime monitoring
Processing Integrity	Data processing is accurate, complete, timely	Quality checks on data pipelines
Confidentiality	Confidential info is protected	Encryption, restricted access to sensitive business data
Privacy	Personal information handled per stated policies	Consent management, data retention limits

SOC 2 Type I vs. Type II

There are two main types of SOC 2 reports.

Feature	SOC 2 Type I	SOC 2 Type II
What it evaluates	Design of controls	Design and operating effectiveness of controls
Time covered	A specific point in time	A period of time
Main question	Are the controls suitably designed?	Are the controls designed appropriately and working effectively over time?
Evidence	Evidence about controls at the specified date	Evidence collected across the audit period

Example: A company implements multi-factor authentication (MFA).

- Type I: The auditor evaluates whether the MFA control is appropriately designed at the specified date.
- Type II: The auditor also evaluates evidence that the control operated effectively throughout the audit period.

How does a SOC 2 audit work?

Step 1: Define the Scope

The company first identifies which services, systems, data are covered.

Step 2: Implement Security Controls

The company then implements security controls such as MFA, access restrictions, encryption and backups.

Step 3: Independent audit

A qualified independent CPA firm examines evidence, test controls and evaluates whether the applicable criteria are met.

Step 4: Issue the report

The auditor issues a report describing the scope, controls, testing and findings.

Feature	NIST CSF	ISO 27001	SOC 2
What it is	Voluntary cybersecurity risk management framework	Certifiable Information Security Management System (ISMS) standard	Independent attestation report
Certifiable?	No	Yes, formal certification	No, report rather than certificate
Who uses it	Organizations of any size or industry	Global organizations, especially those needing formal security certification	Primarily SaaS and technology companies serving US customers
Structure	6 functions: Govern, Identify, Protect, Detect, Respond, Recover	ISMS and Annex A controls: 93 controls across 4 themes in ISO 27001:2022	5 Trust Services Criteria; Security is mandatory, others are optional
Typical use case	Internal risk assessment and cybersecurity improvement	Demonstrating a structured security management system to clients	Demonstrating the effectiveness of security controls to customers
When to choose it	When an organization wants to assess and improve its cybersecurity posture	When formal, internationally recognized certification is required	When customers request independent assurance of security controls, particularly US SaaS clients

When should a company use which?

- SOC 2: A startup selling software or cloud services to US customers may prioritize SOC 2 to demonstrate that its security controls have been independently audited.

- ISO 27001: A company operating globally or serving enterprise clients that require formal security certification may choose ISO 27001.
- NIST CSF: An organization can use NIST CSF to identify security gaps, prioritize risks, and improve cybersecurity without obtaining a certification.
- Combined approach: A company can use NIST CSF internally while pursuing SOC 2 or ISO 27001 to satisfy customer requirements.